

Patient Data Handling and Consent Standard

Meridian Health Partners

Data Handling Standard

Policy Number: MHP-DH-001-V3.0

Effective Date: 2024-07-01

Review Date: 2025-07-01

Approved By: Executive Leadership Team

Owner: Operations Policy Lead

1. Purpose

1.1. This standard establishes consistent requirements for the ethical, secure, and compliant handling of all Personal Data and Sensitive Personal Data collected, processed, and stored by Meridian Health Partners (MHP) across its 14 outpatient sites.

1.2. Adherence to this standard ensures MHP's compliance with applicable data protection regulations, specifically the DPDP Act 2023 and the Health Insurance Portability and Accountability Act (HIPAA).

2. Scope

2.1. This standard applies to all MHP personnel, contractors, volunteers, and third-party vendors who access, process, or manage data on behalf of MHP, regardless of data format (electronic, paper, verbal).

3. Consent Capture and Management

3.1. Explicit, informed consent shall be obtained from all Data Principals for the collection, processing, and storage of their Personal Data and Sensitive Personal Data.

3.2. Consent forms shall be presented in clear, plain language, detailing:

3.2.1. The specific categories of data to be collected.

3.2.2. The precise purpose(s) for data processing.

3.2.3. The identities of MHP departments or external entities with whom data may be shared.

3.2.4. The Data Principal's right to withdraw consent at any time, and the process for doing so.

3.3. For in-person interactions, consent shall be documented via the "MHP Patient Consent Form 2.1." This form requires the signature of the Data Principal or their legally authorized representative and must be witnessed by a Meridian Health Partners staff member (e.g., Front Desk Coordinator, Registered Nurse).

3.4. For digital interactions (e.g., patient portal registration), consent shall be captured via an affirmative action (e.g., checking a box labeled "I agree to the Meridian Health Partners Data Privacy Policy") and timestamped within the MHP Electronic Health Record (EHR) system, 'MediCareFlow 3.5'.

3.5. A complete record of consent, including its scope and date obtained, must be stored within the Data Principal's primary record in 'MediCareFlow 3.5'.

3.6. In instances where a Data Principal withdraws consent, the Data Protection Officer (Dr. Anya Sharma) must be notified within 2 business days to assess implications for ongoing care or service delivery.

4. Minimum Necessary Access

4.1. Access to Personal Data and Sensitive Personal Data shall be granted strictly on a 'need-to-know' and 'need-to-do' basis, meaning personnel are only authorized to access the minimum amount of data required to perform their specific job functions.

4.2. All access permissions are role-based and provisioned by the IT Department under the direct supervision of Mr. Raj Patel (IT Security Manager).

4.3. Role-based access matrices are reviewed and updated quarterly by relevant Department Heads and the IT Security Manager to ensure ongoing accuracy and compliance.

4.4. Personnel are granted access to specific modules or data sets within 'MediCareFlow 3.5' or other MHP systems relevant to their assigned duties.

4.4.1. Example: A Billing Specialist may access patient demographic and insurance information but is restricted from accessing clinical progress notes.

4.4.2. Example: A Registered Nurse may access full clinical records for their assigned patients but not

financial billing details.

4.5. Access logs for all systems containing Personal Data are automatically generated and retained for a minimum of 3 years. These logs are subject to random audits by the Compliance Officer (Ms. Lena Hanson) on a monthly basis.

4.6. Upon a change of role or termination of employment, system access shall be revoked or adjusted within 4 business hours by the IT Department, following formal notification from Human Resources.

5. Data Retention Periods

5.1. All Personal Data and Sensitive Personal Data shall be retained only for the period necessary to fulfill the purposes for which it was collected, or as required by applicable law or regulation, whichever period is longer.

5.2. Specific retention periods are as follows:

5.2.1. Clinical Health Records (e.g., diagnoses, treatment plans, progress notes, imaging reports): 10 years from the date of the last patient interaction or, for minors, 10 years after they reach the age of majority (18 years), whichever is later.

5.2.2. Financial and Billing Records (e.g., invoices, payment histories, insurance claims): 7 years from the date of final transaction or claim settlement.

5.2.3. Patient Consent Forms and Authorization Records: Retained for the duration of the associated clinical record plus an additional 3 years.

5.2.4. Employee Personnel Records (for Meridian Health Partners staff): 7 years post-termination of employment.

5.2.5. Administrative Correspondence (non-clinical, non-financial): 3 years from the date of creation.

5.3. Data subject to legal hold or ongoing investigation shall be retained indefinitely until the legal hold is formally lifted by MHP Legal Counsel.

5.4. At the end of the specified retention period, data shall be securely disposed of using methods compliant with industry best practices (e.g., cross-shredding for physical records, certified data sanitization for digital records), overseen by the Records Management Department and verified by the IT Security Manager.

6. Patient Data-Access Request Process

6.1. Data Principals have the right to request access to their Personal Data held by Meridian Health Partners.

6.2. Requests must be submitted in writing via the "MHP Data Access Request Form 1.0" or through the secure patient portal. Verbal requests must be immediately documented on the aforementioned form by the receiving staff member (e.g., Patient Services Representative).

6.3. All data access requests shall be directed to the Patient Services Department.

6.4. Identity verification of the Data Principal is mandatory prior to processing any request. Acceptable forms of verification include government-issued photo identification or confirmed login credentials for the patient portal.

6.5. The Patient Services Department shall log the request in the 'MHP Request Tracker' system and forward it to the Data Protection Officer (Dr. Anya Sharma) for review and approval within 2 business days of receipt.

6.6. Meridian Health Partners shall provide the requested data within 30 calendar days of receiving a valid, verified request.

6.7. If the requested data cannot be provided within the 30-day timeframe due to exceptional complexity or volume, the Data Principal shall be notified in writing of the delay and the specific reason,

along with an estimated new completion date, which shall not exceed an additional 30 calendar days beyond the initial deadline.

6.8. Data will be provided in a readily intelligible and accessible format, typically via the secure patient portal or a secure, encrypted digital transfer method. Physical copies will be provided only upon specific request and may incur a reasonable fee, as per the "MHP Fee Schedule for Record Duplication 1.2".

6.9. In cases where the request is deemed unfounded, vexatious, or excessive, Meridian Health Partners reserves the right to charge a reasonable fee or refuse to act on the request, in accordance with applicable regulations. Such decisions must be approved by the Data Protection Officer and thoroughly documented.

7. Data Breach Notification Timeline

7.1. A 'Data Breach' is defined as a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, Personal Data transmitted, stored, or otherwise processed.

7.2. Internal Reporting: Any staff member discovering or suspecting a data breach must immediately (within 1 hour of discovery) report it to their direct supervisor and the IT Security Manager (Mr. Raj Patel) via the designated 'MHP Incident Reporting System'.

7.3. Initial Assessment: The IT Security Manager, in conjunction with the Data Protection Officer (Dr. Anya Sharma), shall conduct an initial assessment of the breach within 24 hours of its reporting to determine its scope, severity, and potential impact.

7.4. Regulatory Notification (DPDP Act 2023): If the breach poses a significant risk to the rights of Data Principals, the Data Protection Officer shall notify the Data Protection Board of India (or other relevant supervisory authority as applicable under the DPDP Act 2023) without undue delay and, where feasible, not later than 72 hours after becoming aware of the breach.

7.5. Individual Notification (HIPAA): If the breach involves Protected Health Information (PHI) and compromises its security or privacy, Meridian Health Partners shall notify affected individuals without undue delay and in no case later than 60 calendar days after discovery of the breach. Notifications shall include:

7.5.1. A brief description of what happened.

7.5.2. The types of unsecured PHI involved.

7.5.3. Steps individuals should take to protect themselves from potential harm.

7.5.4. A brief description of what Meridian Health Partners is doing to investigate the breach, mitigate harm, and prevent further breaches.

7.5.5. Contact information for inquiries.

7.6. Media Notification (HIPAA): If a breach affects 500 or more individuals, Meridian Health Partners shall also notify prominent media outlets serving the state or jurisdiction without undue delay and in no case later than 60 calendar days after discovery of the breach.

7.7. Breach Log: All breaches, regardless of severity or notification requirement, must be documented in the 'MHP Data Breach Log,' maintained by the Data Protection Officer for a minimum of 6 years.

7.8. Post-Breach Review: A Root Cause Analysis and corrective action plan shall be developed and implemented for all confirmed breaches, overseen by the Compliance Officer (Ms. Lena Hanson) and the Data Protection Officer.